

מודול 16 — כתיבת דוח ותיעוד

חומר לימוד

1 יחידות

תוכן העניינים

1. מודול 16 — כתיבת דוח ותייעוד (Reporting)

📖 **הכול בגלילה אחת:** כל החומר של המודול בקובץ אחד — חומר לימוד, תרגילים, תרגול ופתרונות, ברצף.

🎬 **מודול מעשי — כתוב דוח אמיתי!** קיבלת הערות שדה גולמיות (`findings_raw.md`) מבדיקה על ACME — המבוססות על החולשות שניצלת לאורך הקורס. בהדגמות תהפוך אותן ל**ממצאים מקצועיים**, תדרג ב-CVSS, ותכתוב **תקציר מנהלים**. אחרי כל הדגמה: 🧠 **בדוק את עצמך**.

מודול 16 — כתיבת דוח ותיעוד (Reporting)

מטרות המודול: ללמוד את המיומנות שמפרידה בין האקר לאיש מקצוע — כתיבת דוח בדיקת חדירה. הדוח הוא המוצר שהלקוח משלם עליו. נלמד מבנה דוח, כתיבת ממצא מקצועי, דירוג חומרה (CVSS), תקצירים למנהלים, המלצות תיקון, וניהול תהליך הבדיקה (Scope, RoE, תיעוד תוך-כדי).

קבצים: `slides.md` · `practice.md` · `solutions.md` · `missions.md` · `README.md`

למה זה חשוב? הלקוח לא רואה אותך פורץ — הוא רואה את הדוח. בדיקה מבריקה עם דוח גרוע = כישלון; ממצא בינוני שמתועד היטב = ערך אמיתי. **דוח טוב הוא כרטיס הביקור המקצועי שלך**, ובבחינות PNPT/OSCP הוא חלק מהציון.

תוכן העניינים

1. למה הדוח הוא המוצר
2. שלבי הבדיקה מסביב לדוח
3. מבנה דוח בדיקת חדירה
4. תקציר מנהלים (Executive Summary)
5. כתיבת ממצא מקצועי
6. דירוג חומרה — CVSS
7. המלצות תיקון
8. תיעוד תוך-כדי וכלים

16.1 למה הדוח הוא המוצר

בדיקת חדירה מספקת ללקוח **שני** דברים: הפחתת סיכון, ו**מסמך** שמוכיח ומסביר אותו. הדוח: - **מתרגם** ממצאים טכניים לשפה עסקית (סיכון, כסף, רגולציה). - **מדריך** את צוות ה-IT כיצד לתקן. - **מתעד** לצרכי ציות (Compliance: PCI-DSS, ISO 27001, GDPR). - **מוכיח** את הערך של הבדיקה מול ההנהלה.

🎯 כלל אצבע: השקע ~30% **מזמן הבדיקה** בתייעוד ובכתיבת הדוח. ממצא שלא תועד — כאילו לא נמצא.

16.2 שלבי הבדיקה מסביב לדוח

הדוח לא נכתב בסוף — הוא מתחיל **לפני** הבדיקה:

1. **Pre-Engagement** — הגדרת **Scope** (מה נבדק), **Rules of Engagement (RoE)** (מתי, איך, מגבלות), **NDA** ומכתב הרשאה.
2. **תיעוד תוך-כדי** — כל צעד, פקודה, צילום מסך, ותוצאה — **בזמן אמת** (אי אפשר לשחזר אחר-כך).
3. **Reporting** — ארגון הממצאים, כתיבה, דירוג, עריכה.
4. **Debrief** — הצגת הדוח ללקוח, מענה לשאלות.
5. **Retest** (לעיתים) — אימות שהתיקונים בוצעו.

⚠️ בלי **Scope** ו-**RoE** ברורים בכתב — אתה חשוף משפטית. זה השלב הראשון והחשוב ביותר, לפני כל nmap.

16.3 מבנה דוח בדיקת חדירה

דוח מקצועי סטנדרטי כולל:

חלק	תוכן
1. שער ופרטים	לקוח, תאריכים, גרסה, סיווג (Confidential)
2. Executive Summary	תקציר לא-טכני להנהלה
3. היקף ומתודולוגיה	מה נבדק, איך, מתי (Scope, RoE)
4. סיכום ממצאים	טבלה: ממצא + חומרה + סטטוס
5. ממצאים מפורטים	כל ממצא: תיאור, PoC, השפעה, תיקון
6. נספחים	פליטים גולמיים, כלים, רשימת מכונות

💡 שני קהלים, שתי שפות: ההנהלה קוראת את ה-Executive Summary (סיכון עסקי); צוות ה-IT קורא את הממצאים המפורטים (איך לתקן). הדוח משרת את שניהם.

16.4 תקציר מנהלים (Executive Summary)

הדף החשוב ביותר — נקרא ע"י מי שמחליט על התקציב, ללא רקע טכני: - מה נבדק ולמה (משפט-שניים). - תמונת מצב כללית — רמת הסיכון הכוללת ("נמצאו 3 חולשות קריטיות המאפשרות השתלטות מלאה"). - הסיכון העסקי — מה זה אומר לארגון (חשיפת נתוני לקוחות, קנס רגולטורי, מוניטין). - המלצות מפתח — 3-5 פעולות עליונות.

כתוב בשפה עסקית, לא טכנית:

✗ "SQLi UNION-based extraction מאפשר ב-param id"

✓ "חולשה באתר מאפשרת לתוקף לגשת לכל מסד נתוני הלקוחות",
"כולל פרטי אשראי – סיכון קריטי לחשיפת מידע ולקנס רגולטורי"

🎯 אם המנכ"ל קורא רק עמוד אחד — זה העמוד. הוא צריך להבין את הסיכון ולפעול, בלי לדעת מה זה SQL.

16.5 כתיבת ממצא מקצועי

כל ממצא בדוח בנוי במבנה קבוע:

[Critical/High/Medium/Low] חומרה – [כותרת הממצא]

*(פרמטר/URL/מערכת) תיאור: ** מהי החולשה ואיפה היא.

*(Impact) השפעה: ** מה תוקף יכול לעשות איתה, ומה הסיכון העסקי.

*(Proof of Concept (PoC): **

*(צעדים מדויקים לשחזור + פקודות + צילומי מסך

1. ...

2. ...

*(Remediation) המלצת תיקון: ** כיצד לתקן (ספציפי וישים)

*(הפניות: ** CVE, OWASP, CWE.

עקרונות: - ניתן לשחזור — כל צעד מדויק, כך שה-IT יאמת בעצמו. - **ראיות** — צילומי מסך הם קריטיים (מטושטשים היכן שיש מידע רגיש). - **עובדתי ומקצועי** — בלי "התלהבות האקרים"; טון עסקי מכובד.

הדגמה — נסה בעצמך: הפוך הערה גולמית לממצא מקצועי

ניקח הערת שדה אחת מ- `findings_raw.md` ונכתוב אותה כמו בדוח אמיתי.

צעד 1 — קרא את ההערה הגולמית (F-02):

```
cat findings_raw.md          # מצא את F-02 (Command Injection)
```

👁️ הערה טכנית קצרה: “`?host=127.0.0.1;id`” הריץ פקודות...Reverse Shell”.

צעד 2 — כתוב אותה במבנה הממצא המקצועי. צור `report.md` (`nano report.md`) והשלם:

Critical: חומרה – (Command Injection) הזרקת פקודות מערכת

מעביר קלט משתמש (`/ping`) בכלי בדיקת הרשת `host` תיאור: ** הפרמטר **
ללא סינון, ומאפשר הרצת פקודות שרירותיות על השרת shell ישירות לפקודות

לקרוא, (RCE) השפעה: ** תוקף לא-מאומת יכול להריץ קוד כלשהו על השרת **
כלומר להשתלט על המערכת ולהתקדם ברשת – Shell קבצים רגישים, ולפתוח

Proof of Concept:

1. שלח בקשה: `curl "http://ACME/ping?host=127.0.0.1;id"`
2. הוכחת הרצת קוד – `uid=... gid=...` התגובה כללה (צילום: rce_id.png)

עם רשימת API-השתמש ב shell-המלצת תיקון: ** אין להעביר קלט ל**
ולידציה של הקלט + (`subprocess.run(..., shell=False)`) ארגומנטים

הפניות: OWASP A03:2021 (Injection), CWE-78.

👁️ שים לב: תיאור → השפעה → PoC ניתן-לשחזור → תיקון ספציפי → הפניות.

🎯 **מה קרה כאן:** הפכת הערה גולמית למסמך שה-IT יכול לשחזר ולתקן, וההנהלה מבינה את הסיכון. **זה**
המוצר שהלקוח משלם עליו.

🏆 **אתגר:** כתוב באותו מבנה גם את F-01 (SQLi) ו-F-03 (IDOR).

🧠 **בדוק את עצמך:** איזה חלק בממצא הופך אותו ל**ניתן לשחזור** ע"י צוות ה-IT? (א) כותרת הממצא - (ב) ה-
Proof of Concept (צעדים מדויקים + פקודות + צילומים) - (ג) ההפניות ל-CVE

✅ **תשובה: ב** — ה-PoC עם הצעדים המדויקים מאפשר ל-IT לשחזר את החולשה בעצמם, לאמת אותה, ולוודא שהתיקון עבד.

16.6 דירוג חומרה — CVSS

CVSS (Common Vulnerability Scoring System) נותן ציון 0-10 לכל חולשה, לפי מדדים כמו וקטור התקיפה, מורכבות, והשפעה על CIA.

ציון CVSS	חומרה	משמעות
9.0–10.0	Critical	השתלטות מלאה / חשיפת נתונים חמורה — תקן מיד
7.0–8.9	High	סיכון משמעותי
4.0–6.9	Medium	סיכון בינוני, לרוב דורש תנאים
0.1–3.9	Low	סיכון נמוך
0.0	Informational	ללא סיכון ישיר, לתשומת לב

דרג לפי סיכון עסקי, לא רק ציון טכני: SQLi בדף פנימי לא-רגיש עשוי להיות פחות דחוף מ-SQLi בדף לקוחות ציבורי, גם באותו CVSS.

השתמש ב-מחשבון CVSS הרשמי לעקביות. דירוג עקבי ומנומק בונה אמון עם הלקוח.

הדגמה — נסה בעצמך: דרג את הממצאים ב-CVSS

נדרג את 6 הממצאים מ- findings_raw.md ונבנה את טבלת הסיכום הממצאים של הדוח.

צעד 1 — פתח את מחשבון CVSS 3.1 (first.org) ודרג כל ממצא. למשל F-02 (Command Injection, RCE) לא-מאומת מרחוק):

AV:N (רשת) / AC:L (קל) / PR:N (ללא הרשאות) / UI:N / S:U / C:H/I:H/A:H
→ ציון 9.8 = Critical

צעד 2 — בנה את טבלת הסיכום (צור summary.md):

#	חומרה	ממצא	CVSS
F-02	Command Injection (RCE)	Critical	9.8
F-01	SQL Injection (עקיפת התחברות)	Critical	9.1
F-06	Reflected XSS	High	7.4
F-03	IDOR – חשיפת פרופילים	High	7.5
F-04	גרסת שרת פגיעה (Apache 2.4.49)	High	7.5
F-05	סיסמאות חלשות / ללא MFA	High	8.1

מיינ תמיד מהחמור לקל — כך הלקוח יודע מה לתקן קודם.

🎯 **מה קרה כאן:** נתת לכל ממצא ציון אובייקטיבי ועקבי, ובנית את הטבלה שההנהלה וה-IT מסתכלים עליה ראשונה. **דרג לפי סיכון עסקי** — RCE לא-מאומת על שרת ציבורי קודם לכל השאר.

🧠 **בדוק את עצמך:** איזה ממצא יקבל את ה-CVSS הגבוה ביותר, ככלל? - א) Command Injection המאפשר RCE לא-מאומת מרחוק על שרת ציבורי - ב) חולשת Low בדף פנימי - ג) כותרת Server חושפנית

✅ **תשובה: א** — RCE מרחוק, ללא אימות, עם השפעה מלאה על סודיות/שלמות/זמינות = הציון הגבוה ביותר (סביב 9.8-10.0, Critical). זה מה שמתקנים ראשון.

16.7 המלצות תיקון

הערך האמיתי ללקוח — **איך לתקן:** - **ספציפי וישים** — לא “שפר אבטחה”, אלא “החלף שאילתות ל-Prepared Statements בקובץ X”. - **מדורג לפי עדיפות** — Critical קודם. - **קצר וארוך טווח** — Patch מיידי + שיפור מבני (SDLC, הדרכות). - **מקושר לממצא** — כל תיקון פותר ממצא ספציפי.

דוגמאות תיקון לפי סוג (מסכם את הקורס): | חולשה | תיקון | |-----|-----| SQL Injection | Prepared | CSP + Output Encoding | XSS | | Statements / ORM | | חולשת least-privilege | PrivEsc, הסרת SUID/sudo מיותר | | gMSA | AD (Kerberoast), סיסמאות חזקות, כיבוי LLMNR | | סיסמאות חלשות | מדיניות סיסמאות + MFA | | פשינג | הדרכות מודעות + סינון מייל |

16.8 תיעוד תוך-כדי וכלים

תעד בזמן אמת — לא בסוף: - **צילומי מסך** מכל ממצא (Flameshot / Greenshot). - **לוג פקודות** — שמור את כל מה שהרצת (tmux logging, script). - **טבלת ממצאים** מתעדכנת תוך כדי.

כלים לניהול ותיעוד: - **CherryTree / Obsidian / Joplin** — מחברות מובנות לתיעוד תוך-כדי. - **Sysreptor** - **Dradis / PwnDoc** — פלטפורמות ייעודיות לכתיבת דוחות pentest. - **תבניות דוח** — SANS, TCM, OffSec מפרסמות תבניות מצוינות (התחל מהן).

🎯 טיפ זהב: כתוב את הממצא **מיד** כשמצאת אותו, כשהכול טרי. ריכוז 20 ממצאים בסוף השבוע מהזיכרון = ממצאים חסרים ואיכות ירודה.

סיכום המודול

- **הדוח הוא המוצר** — הלקוח משלם עליו; השקע ~30% מהזמן בתיעוד.

- הדוח מתחיל ב-**Pre-Engagement** (Scope, RoE, הרשאה) ומלווה תיעוד תוך-כדי.
- מבנה: שער → **Executive Summary** → מתודולוגיה → סיכום → ממצאים מפורטים → נספחים.
- **Executive Summary** בשפה עסקית להנהלה; **ממצאים** מפורטים ל-IT.
- כל ממצא: תיאור → השפעה → **PoC** → תיקון → הפניות; דרג ב-CVSS.
- **המלצות תיקון** ספציפיות וישימות הן הערך האמיתי; תעד בזמן אמת עם כלים ייעודיים.

🎓 **מזל טוב — סיימת את הקורס!**

עברת את כל שרשרת התקיפה: ממבוא ומעבדה, דרך **Recon**, סריקה, ניצול, הסלמה, **AD** ואלחוט, ועד הדוח המקצועי. עכשיו: ➡ מבחן מעשי מסכם (PNPT/OSCP-style) · בנק שאלות · דוגמאות מהעולם ➡ מסלול המשך: OSCP → PNPT → eJPT

➡ תרגילים — **missions.md** · פתרונות — **solutions.md** · תרגול — **practice.md**

⬅ חזרה למפת הקורס